

HACK THE BOX SHERLOCK - THREAT INTELLIGENCE

FORTYSEVEN-1

Sherlock Scenario

An APT group is using Hajj-themed phishing lures to target and steal WhatsApp data from government and diplomatic officials. Our team has gathered fragmented intelligence from public cybersecurity vendor reports, blog posts, and internal security alerts. Your task is to build a comprehensive profile of the threat actor responsible. You must connect the dots between different reports to answer questions about their identity, tools, and motives.

Below are the sites we have compiled, use these to answer the following questions. (If any of the sites become unavailable please check on wayback machine as they all have been saved).

- Evidence - 1
 - <https://securelist.com/mysterious-elephant-apt-ttps-and-tools/117596/>
- Evidence - 2 -
 - <https://medium.com/@knownsec404team/apt-k-47-mysterious-elephant-a-new-apt-organization-in-south-asia-5c66f954477>
- Evidence - 3 -
 - <https://medium.com/@knownsec404team/unveiling-the-past-and-present-of-apt-k-47-weapon-asyncshell-5a98f75c2d68>

1. What is the primary name of the APT group described in the SecureList report?

Mysterious Elephant is a highly active advanced persistent threat (APT) group that we at Kaspersky GReAT discovered in 2023. It has been consistently evolving and adapting its tactics, techniques, and procedures (TTPs) to stay under the radar. With a primary focus on targeting government entities and foreign affairs sectors in the Asia-Pacific region, the group has been using a range of sophisticated tools and techniques to infiltrate and exfiltrate sensitive information. Notably, Mysterious Elephant has been exploiting WhatsApp communications to steal sensitive data, including documents, pictures, and archive files.

The group's latest campaign, which began in early 2025, reveals a significant shift in their TTPs, with an increased emphasis on using new custom-made tools as well as customized open-source tools, such as BabShell and MemLoader modules, to achieve their objectives. In this report, we will delve into the history of Mysterious Elephant's attacks, their latest tactics and techniques, and provide a comprehensive understanding of this threat.

The answer to this question is **Mysterious Elephant** which is a highly active APT group that was discovered by Kaspersky GReAT in the year of 2023.

2. According to the Knownsec 404 team's analysis(Evidence -3), since which year has this group's attack activity been dated back to?

2. overview

APT-K-47, also known as Mysterious Elephant, was the first APT organization to disclose details of its activities by the Knownsec 404 Advanced Threat Intelligence team [1]. The organization is presumed to have originated in the South Asian region, and its attack activities date back as far as 2022. In an in-depth analysis of APT-K-47's technical approach, tactical strategy, tool usage, and operational goals, multiple other APT organizations in South Asia can be seen, including but not limited to Sidewinder, Confucius, and Bitter.

Here we are told to search on Evidence number 3 Medium article, and here it is stated that the Mysterious Elephant has been active in the South Asian region since **2022**.

3. The group uses a custom backdoor that communicates via Office Remote Procedure Call (ORPCBackdoor). According to the Knownsec 404 team's analysis(Evidence -2), what is the name of the first malicious exported entry function?

```
GetFileVersionInfoA
GetFileVersionInfoByHandle
GetFileVersionInfoExW
GetFileVersionInfoSizeA
GetFileVersionInfoSizeExW
GetFileVersionInfoSizeW
GetFileVersionInfoW
VerFindFileA
VerFindFileW
VerInstallFileA
VerInstallFileW
VerLanguageNameA
VerLanguageNameW
VerQueryValue
VerQueryValue
GetFileVersionInfoByHandleEx(void)
DllEntryPoint
```

There are two malicious entries of ORPCBackdoor, the first is **GetFileVersionInfoByHandleEx(void)** export function, second place is **DllEntryPoint**.

So it is stated then the first and second export functions, and since this question asked for the first then the answer is

GetFileVersionInfoByHandleEx(void)

4. The previously mentioned backdoor checks for a file before creating persistence. What is the name of the file?

2. persistence

ORPCBackdoor determines whether the file exists to prevent multiple persistence. Before persistent creation, ORPCBackdoor determines whether the **ts.dat** file exists in the same path. If the file does not exist, ORPCBackdoor will create persistence. The TaskScheduler CLSID is invoked by COM, which name is Microsoft Update. After the task is created, the ts.dat file is created.

Here it is saying that the ORPCBackdoor determines whether the file exists under the same path for persistence, and that file is **ts.dat**

5. The use of the backdoor links the APT to another well-known South Asian APT group. What is the name of this other group?

Highlight

Share

we identified the weapon as the latest weapon used by **BITTER**. However, we noticed that Kaspersky recently released a report saying that they had discovered a new **APT** group in the second quarter, and that the group’s main target was Pakistan. It was named the “Mysterious Elephant”.

Here in the screenshot above, it stated that the latest weapon was used by another APT group, called **Bitter**.

6. The APT group we are currently investigating has consistently used and updated another backdoor since 2023, with its C2 communication evolving from TCP to HTTPS. What is the name of this tool?

差异项 版本	初始活跃	通信协议	log信息	加载方式	C2获取方式	指令类型
v1	2023.9	TCP	√	CVE-2023-38831 CHM加载执行	硬编码	CMD Powershell
v2	2024.4	Https	√	CHM加载执行 PDF文档伪装	硬编码	CMD
v3	2024.7	TCP	√	Ink+vbs	解密文件	CMD
v4	2024.9	Http TCP	×	CHM加载执行	服务端分发	CMD

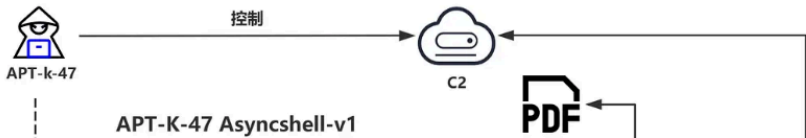
The following describes the discovery process and version updates of Asyncshell on a timeline.

4.1 Discover Asyncshe

Highlight

Share

Our team first discovered **Asyncshell** back in January 2024, when we found a malicious sample exploiting the CVE-2023-38831 vulnerability, with the overall attack chain shown below:



Here we found in the tool that changed C2 communication from TCP to HTTPS, and the tool is called **Asyncshell-v2**, since the v2 is when it changed from TCP to HTTPS, instead of v1.

7. To evade sandbox analysis, the MemLoader HidenDesk tool checks the number of active processes before running. What is the minimum number of processes required for it to proceed?

Customized open-source tools

One of the latest modules used by Mysterious Elephant and loaded by BabShell is MemLoader HidenDesk.

MemLoader HidenDesk is a reflective PE loader that loads and executes malicious payloads in memory. It uses encryption and compression to evade detection.

MemLoader HidenDesk operates in the following manner:

- 1 The malware checks the number of active processes and terminates itself if there are fewer than 40 processes running — a technique used to evade sandbox analysis.

There described the HidenDesk tool and it checks for **40** processes, otherwise it will terminate itself

8. The MemLoader HidenDesk tool creates a covert environment for its activities by creating and switching to a specific environment. What is the name of this hidden desktop?

- 3 The malware then creates a hidden desktop named "**MalwareTech_Hidden**" and switches to it, providing a covert environment for its activities. This technique is borrowed from an open-source project on GitHub.

In the screenshot above, it is stated that the malware creates a hidden desktop called as **MalwareTech_Hidden**

9. The MemLoader HidenDesk tool achieves persistence by placing a shortcut in the autostart folder to ensure it runs after a system reboot. What is the MITRE ATT&CK ID for the 'Registry Run Keys / Startup Folder' technique?

Boot or Logon Autostart Execution

Sub-techniques (14) ^	
ID	Name
T1547.001	Registry Run Keys / Startup Folder
T1547.002	Authentication Package
T1547.003	Time Providers
T1547.004	Winlogon Helper DLL
T1547.005	Security Support Provider
T1547.006	Kernel Modules and Extensions
T1547.007	Re-opened Applications
T1547.008	LSASS Driver
T1547.009	Shortcut Modification

The answer can be found at this link:

<https://attack.mitre.org/techniques/T1037/>

Here we can spot under the tactic of Boot or Logon Autostart Execution, and the technique of Registry Run Keys / Startup Folder and the answer is **T1547.001**

10. The actor uses several custom exfiltration tools targeting WhatsApp. What is the name of the tool that recursively searches specific directories, including the "Desktop" and "Downloads" folders?

The **Stom Exfiltrator** is a commonly used exfiltration tool that recursively searches specific directories, including the "Desktop" and "Downloads" folders, as well as all drives except the C drive, to collect files with predefined extensions. Its latest variant is specifically designed to target files shared through the WhatsApp application. This version uses a hardcoded folder path to locate and exfiltrate such files:

```
%AppData%\Packages\xxxxx.WhatsAppDesktop_[WhatsApp ID]\\LocalState\\Shared\\transfers\\
```

The targeted file extensions include .PDF, .DOCX, .TXT, .JPG, .PNG, .ZIP, .RAR, .PPTX, .DOC, .XLS, .XLSX, .PST, and .OST.

Here we see **Stom Exfiltrator**, which is an exfiltration tool that searches specific directories such as Desktop and Downloads folders, and is designed to target files shared through WhatsApp.

11. Kaspersky's analysis highlights the actor's heavy use of scripts for execution and deploying payloads. What is the MITRE ATT&CK ID for the 'PowerShell' technique?

Command and Scripting Interpreter

Sub-techniques (13) ^	
ID	Name
T1059.001	PowerShell
T1059.002	AppleScript
T1059.003	Windows Command Shell
T1059.004	Unix Shell
T1059.005	Visual Basic
T1059.006	Python
T1059.007	JavaScript
T1059.008	Network Device CLI
T1059.009	Cloud API

The answer can be found at this link:

<https://attack.mitre.org/techniques/T1059/>

I found this under the Command and Scripting Interpreter tactic and I found the Powershell technique which has an ID of **T1059.001**

12. In their early attack chains, Mysterious Elephant used a downloader that was previously associated with the Origami Elephant group. What was the name of this downloader?

The emergence of Mysterious Elephant

Mysterious Elephant is a threat actor [we've been tracking since 2023](#). Initially, its intrusions resembled those of the Confucius threat actor. However, further analysis revealed a more complex picture. We found that Mysterious Elephant's malware contained code from multiple APT groups, including Origami Elephant, Confucius, and SideWinder, which suggested deep collaboration and resource sharing between teams. Notably, our research indicates that the tools and code borrowed from the aforementioned APT groups were previously used by their original developers, but have since been abandoned or replaced by newer versions. However, Mysterious Elephant has not only adopted these tools, but also continued to maintain, develop, and improve them, incorporating the code into their own operations and creating new, advanced versions. The actor's early attack chains featured distinctive elements, such as remote template injections and exploitation of [CVE-2017-11882](#), followed by the use of a downloader called "Vtyrei", which was previously connected to Origami Elephant and later abandoned by this group. Over time, Mysterious Elephant has continued to upgrade its tools and expanded its operations, eventually earning its designation as a previously unidentified threat actor.

Here it is said that Mysterious Elephant used a tool connected to the Origami Elephant and used a downloader called **Vtyrei**.

13. In a January 2024 campaign delivering an Asyncshell payload, which CVE was exploited in the malicious archive file?

4.1 Discover Asyncshell for the first time

Our team first discovered Asyncshell in a January 2024 campaign, when we found a malicious sample exploiting the [CVE-2023-38831](#) vulnerability, with the overall attack chain shown below:

As of January 2024, the campaign exploited a vulnerability which is **CVE-2023-38831**.

14. What is the MD5 hash of the ChromeStealer Exfiltrator sample named WhatsAppOB.exe?

ChromeStealer Exfiltrator

[9e50adb6107067ff0bab73307f5499b6](#) WhatsAppOB.exe

Here in the screenshot above, we see the MD5 hash of the ChromeStealer Exfiltrator named WhatsAppOB.exe, which is **9e50adb6107067ff0bab73307f5499b6**.

15. The intelligence describes multiple custom tools designed to upload stolen data to the actor's servers. According to the MITRE ATT&CK framework, what is the ID for the 'Exfiltration Over C2 Channel' technique?

Exfiltration Over C2 Channel

Adversaries may steal data by exfiltrating it over an existing command and control channel. Stolen data is encoded into the normal communications channel using the same protocol as command and control communications.

ID: **T1041**

Sub-techniques: No sub-techniques

① **Tactic:** Exfiltration

① **Platforms:** ESXi, Linux, Windows, macOS

Contributors: William Cain

Version: 2.3

Created: 31 May 2017

Last Modified: 24 October 2025

[Version Permalink](#)

Since this has no techniques under the tactic so it is only the ID we take which is **T1041**.



You have solved FortySeven-1!

Congratulations  **rafaelangelo** best of luck in capturing flags ahead!

#158	19 Apr 2026	Active
Sherlock Rank	Solve Date	Sherlock State

[Ok](#) [Share](#)